

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

Unpatched Systems Vulnerable to Spoofed Linked Certificates in KDC

Date of Publication

January 24, 2023

Admiralty Code

A1

TA Number

TA2023041

Summary

First appeared: May 10, 2022

Affected Products: Windows Server

Attack: CVE-2022-26923 is a vulnerability that can cause an elevation of privilege when the Kerberos Distribution Center (KDC) services a certificate-based authentication request. Unpatched systems are vulnerable to spoofed linked certificates in a variety of ways because certificate-based authentication does not properly validate a dollar sign (\$) at the end of a machine name.

CVE

CVE	NAME	PATCH
CVE-2022-26923	Active Directory Domain Services Elevation of Privilege Vulnerability	

Attack Details

#1

Windows Server provides Public Key Infrastructure (PKI) technology to enable capabilities such as Encrypting File System (EFS), domain authentication, digital signatures, and email security. Misconfigurations in Active Directory Certificate Services (AD CS) role services may expose them to cyber attacks such as privilege escalation, Golden Ticket Attacks, and AD Domain domination.

#2

The 'Request Certificates' permission is enabled by default, allowing an authenticated user to modify computer account parameters and obtain a certificate from AD CS, potentially leading to privilege elevation on a Domain Controller. The vulnerability occurs due to lack of proper security enforcement in Active Directory Domain Services. It is important for administrators to implement all necessary safeguards for their AD CS servers to prevent attacks.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.



Potential MITRE ATT&CK TTPs

TA0002 Execution	TA0004 Privilege Escalation	TA0005 Defense Evasion	TA0007 Discovery
TA0011 Command and Control	T1106 Native API	T1059 Command and Scripting Interpreter	T1134 Access Token Manipulation
T1049 System Network Connections Discovery	T1078 Valid Accounts	T1553 Subvert Trust Controls	T1068 Exploitation for Privilege Escalation



Patch Link

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-26923>



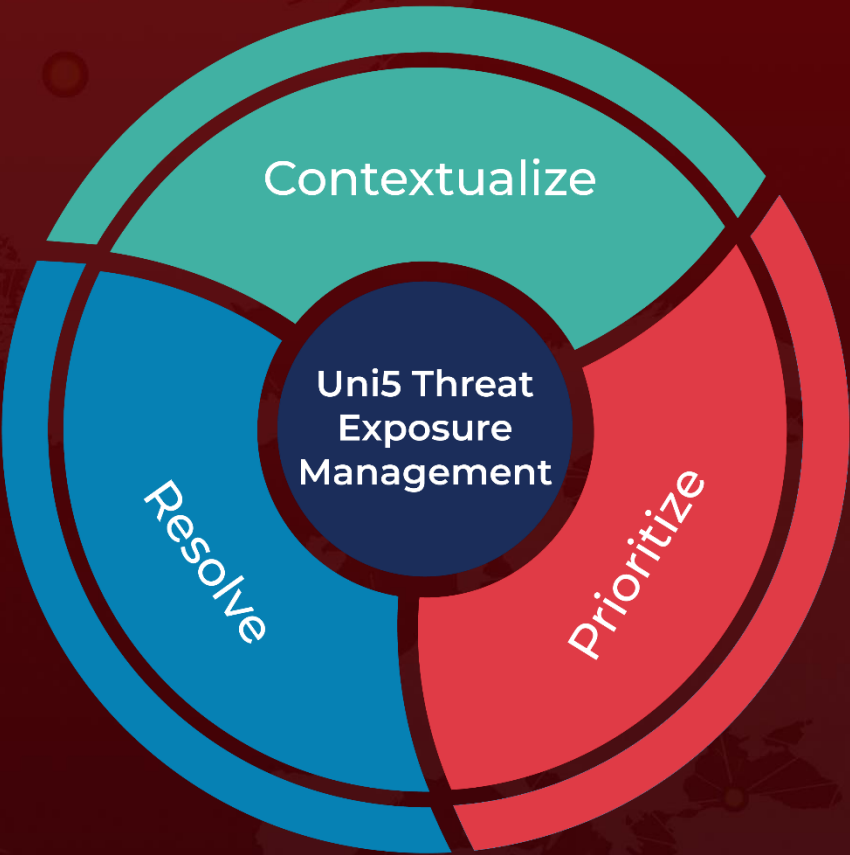
References

<https://www.sentinelone.com/blog/dollar-signs-in-attackers-eyes-how-to-mitigate-cve-2022-26923/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

January 24, 2023 • 2:00 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com